La sécurité Informatique

Compétences	Détails
C04 – Analyser une structure matérielle et logicielle	*Connaissances associées :* - *Bonnes pratiques en sécurité informatique* - *Menaces, vulnérabilités et risques* - *Types d'attaques (DoS, usurpation, social engineering)* - *Contre-mesures* *Activités professionnelles :* *R3 – Exploitation* *R5 – Maintenance* *D3 – Gestion d'incidents*
C10 – Exploiter un réseau Informatique	
C11 – Maintenir un réseau Informatique	

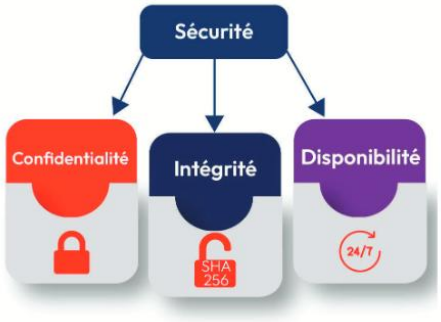
Modalités :

- Cours théorique en classe entière
- CTF simple
- Immersion en SIO

Objectifs de la sécurité

Les trois objectifs de la cybersécurité sont :

- La confidentialité : s'assurer que les données soient lisibles UNIQUEMENT par les personnes détenant l'autorité
- Intégrité des données : S'assurer que les données ne soient pas corrompues.
- Disponibilité : la garantie d'un accès permanent aux données pour toute personne autorisée.



Terminologie de la sécurité informatique

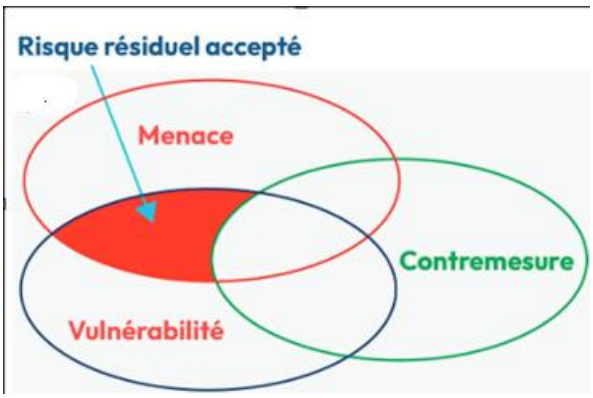
The Asset (l'atout) : c'est une chose qui doit être protégée, on inclut :

- Les personnes
- Les biens
- Les données

Les menaces : c'est un danger existant dans l'environnement des SI, par exemple :

- Les criminels
- Les pirates
- Un employé mécontent
- Les concurrents

Les vulnérabilités : une faiblesse des SI.



Les contremesures : méthode de contrôle de la mise en œuvre d'une menace :

- Contre mesure administrative
- Contre mesure physique

Le risque résiduel accepté : risques subsistants après la mise en œuvre des contre-mesures.

Les acteurs des menaces

Les acteurs de menaces en cyber sécurité informatique sont des individus ou des groupes qui cherchent à exploiter les vulnérabilités des SI.

Les pirates :

- Les pirates à chapeau blanc (white hat) : ce sont des pirates éthiques qui utilisent leurs compétences pour améliorer les SI.
- Les pirates à chapeau gris (Grey Hat) : ce sont des criminels non éthiques qui utilisent leurs compétences pour des raisons malveillantes.
- Les pirates à chapeau noir **(Black Hat)** : ce sont des pirates non éthiques, qui ont pour but de nuire à d'autres personnes ou organisations.

Mais aussi on a :

Les scripts kiddies (les pirates néophytes) : ce sont des pirates qui n'ont pas beaucoup d'expérience et qui exécutent des scripts open source.

Les pentester (testeur de vulnérabilité) : des pirates à chapeau blanc, qui test la vulnérabilité des SI.

Les cybercriminels : des pirates à chapeau noir qui travaillent pour des organisations criminelles.

Les parrainé par l'état : ce sont des pirates chapeau noir ou blanc qui sont recrutés par l'état.

Les outils de sécurité

OUTILS	RÔLES	EXEMPLES
Craqueurs de mots de passe	La récupération des mots de passe	• John the Ripper • Ophcrack • L0phtCrack • THC Hydra • RainbowCrack • Medusa
Outils de piratage sans fil	Piratage des réseaux sans fil	• Aircrack-ng • Kismet • InSSIDer • KisMAC • Firesheep • NetStumbler
Outils d'analyse et de piratage réseau	Analyse du réseau pour trouver la liste des machines disponibles, les ports ouverts, etc.	• Nmap • SuperScan • Angry IP Scanner • NetScanTools
Outils de création de paquets	Test de la robustesse d'un pare-feu en utilisant des paquets forgés (Spoofés)	• Hping • Scapy • Socat • Yersinia • Netcat • Nping • Nemesis

OUTILS	RÔLES	EXEMPLES
Renifleurs de paquets	Capture et analyse des paquets au sein d'un réseau.	• Wireshark • Tcpdump • Ett ercap • Dsniff • EtherApe • Paros • Fiddler • Ratproxy • SSLstrip
Détecteurs de rootkit	Vérification de l'intégrité des répertoires et des fichiers.	• AIDE • Netfi lter • PF: OpenBSD Packet Filter
Générateurs de bruits (Fuzzers)	Découverte des vulnérabilités.	• Skipfi sh • Wapiti • W3af
Outils d'investigation	Découverte des traces de preuves existant dans une machine.	• Sleuth Kit • Helix • Maltego • Encase
Débogueurs	L'ingénierie inverse sur des fichiers binaires lors de l'écriture d'exploits.	• GDB • WinDbg • IDA Pro • Immunity Debugger
Piratage de systèmes d'exploitation	Systèmes d'exploitation conçus pour le piratage.	• Kali Linux • Knoppix • BackBox Linux
Outils de chiffrement	Le chiffrement des données	• VeraCrypt • CipherShed • OpenSSH • OpenSSL • Tor • OpenVPN • Stunnel
Outils d'exploitation des vulnérabilités	Vérification si une machine est vulnérable à une attaque ou non.	• Metasploit • Core Impact • Sqlmap • Social Engineer Toolkit • Netsparker
Analyseurs de vulnérabilité	Identification des ports ouverts, recherche des vulnérabilités, etc.	• Nipper • Secunia PSI • Core Impact • Nessus v6 • SAINT • Open VAS

Types d'attaques

Attaques	**Descriptions**
Attaques d'écoute	Capture et surveillant du trafic
Attaque par modification de données	Attaque de modification des données à l'insu de l'expéditeur et du destinataire
Attaque par usurpation IP	Construction de paquet qui semble provenir d'une adresse IP valide
Attaque basée sur les mots de passes	Piratage du compte utilisateur de la victime
Attaque par déni de service	Rendre inaccessible un service (ex : DHCP)
MITM (Man In The Middle)	Positionnement entre la source et la destination pour surveiller la capture et contrôler la communication
Attaque à clé compromise	Accès à une communication sécurisée à l'insu de l'expéditeur et du destinataire
Attaque de reniflement (Sniffer)	Surveillance et capture des échanges de données réseau

Les attaques réseaux courantes

Les attaques de reconnaissances

Ce sont des attaques utilisées pour la collecte d'informations à propos de la cible :

- Trouver des informations personnelles
- Trouver des adresses IP
- Trouver des ports ouverts
- Trouver le système installé
- Rechercher les applications installées
- Trouver des vulnérabilités

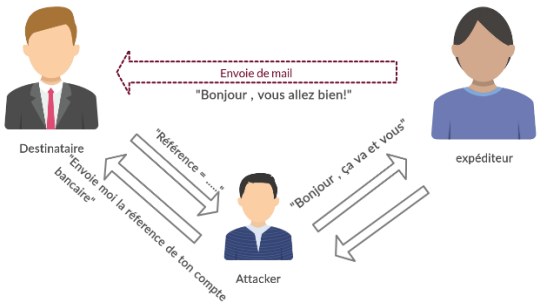
Les attaques par usurpation

L'attaque par usurpation : la machine de l'hacker se fait passer pour une machine légale. Il usurpe :

- L'adresse MAC
- L'adresse IP
- Le service (DHCP, DNS…)

Exemple :

L'attaque MITM (Man In The Middle) elle utilize l'ARP et l'IP spoofing combinée :



Le social engineering

C'est une attaque qui utilise les failles humaines, les techniques utilisés sont :

- Prétexte : On prétexte une urgence par exemple
- Hameçonnage (Phishing)
- Courier indésirable (SPAM)
- Contre partie (something for something)
- Espionage au-dessus de l'épaule (Shoulder Surfing)
- Fouille de la poubelle (Dumpster Diving)